الجمهورية اليمنية
وزارة التربية والتعليم والبحث العلمي
الجامعة اليمنية
كلية الهندسة وعلوم الحاسوب — قسم هندسة الأمن السيبراني والشبكات

تقرير الفحص الفني والتحقيق الجنائي الرقمي في سجلات أحداث النظام

Technical Report: Advanced Digital Forensics & Incident Response (DFIR) Analysis

إعداد الطالب / المحلل:	رفعت مختار	**تاريخ إجراء التحليل:**	15 سبتمبر 2026
المرجع التقني للحادث:	DFIR-IR-2026-FUDU2-ENTERPRISE	**تصنيف درجة الخطورة:**	حرج ومرتفع الخطورة (Critical)
الخادم الرئيس المتأثر:	WIN-FUDU2CKJOE8 (Windows Server)	**الأنظمة المرتبطة بنطاق التدقيق:**	VALKYRIE | IE10Win7
المستخرج الجنائي المعتمد:	analysis_results.csv (4.4 MiB)	**حالة المراجعة والتدقيق:**	مكتمل ومثبت بالأدلة الرقمية المباشرة
إشراف الدكتور:	د / أيمن العنسي	**المادة المقررة:**	تحليل الثغرات والتهديدات

الفهرس الهيكلي للدراسة الفنية (Table of Contents)

1. وثيقة سلامة الأحراز وسلسلة العهدة الرقمية (Chain of Custody & Evidence Verification)
2. المقدمة ونطاق الفحص الفني (Investigation Scope & Objectives)
3. الأسس النظرية والمعمارية الهندسية لتحليل السجلات (Technical Architecture & Methodology)
    1.3 معمارية سجلات Windows الثنائية (EVTX Binary XML Architecture)
    2.3 منهجية الفرز السلوكي وتصفية الضوضاء التشغيلية عبر محرك Hayabusa وقواعد Sigma
    3.3 ميكانيكية تدقيق كتل الأوامر البرمجية (Script Block Logging - Event ID 4104)
4. التحليل الفني التطبيقي وتتبع مسار التنفيذ (Technical Execution Flow Analysis)
    1.4 الطور الأول: الفرز الشامل، قياس الكثافة التهديدية، وتحديد مركز الاستهداف (Triage Phase)
    2.4 الطور الثاني: تشريح محاولة إنزال أدوات التحكم وتأسيس منصات C2 (Event ID 1116)
    3.4 الطور الثالث: كشف التحرك الجانبي وتصعيد الصلاحيات عبر PsExec (Event ID 1 & 7045)
    4.4 الطور الرابع: التشريح المجهري للتنفيذ البرمجي في مساحة الذاكرة دون ملفات (Event ID 4104)
    5.4 الطور الخامس: استخراج بيانات الاعتماد وضمان التثبيت في النظام (LSASS Memory Dump & Persistence)
5. إعادة بناء الخط الزمني الكرونولوجي المتكامل للأحداث (Master Chronological Timeline)
6. المواءمة المعيارية مع مصفوفة تقنيات التهديد (MITRE ATT&CK Enterprise Framework)
7. مصفوفة مؤشرات الاختراق التقنية المعتمدة (Actionable IOC Ledger)
8. تحليل الأسباب الجذرية والثغرات التكوينية (Root Cause & Gap Analysis)
9. خطة الاحتواء الفني والتوصيات الهندسية للتحصين (Hardening & Mitigation Roadmap)

1. وثيقة سلامة الأحراز وسلسلة العهدة الرقمية (Chain of Custody & Evidence Verification)

امتثالاً لمتطلبات المعيار الدولي ISO/IEC 27037 الخاص بإجراءات اكتساب وتوثيق الأدلة الرقمية لضمان موثوقيتها الفنية وتجنب الطعن في سلامتها المادية، قمتُ بتطبيق تدابير العزل والتحقق الحسابي للبصمات الرياضية المشفرة (Cryptographic Hashes) لكافة ملفات السجلات الخام فور استلامها وقبل تمريرها لأي معالجة تحليلية:

معرّف الدليل	المسار المادي لملف السجل	القناة التدقيقية (Channel)	حالة التحقق وسلامة البيانات
EVT-SEC-01	logs/Security.evtx/..	Windows Security Audit Log	مطابقة تامة لبصمة SHA-256 (سلامة فيزيائية مثبتة)
EVT-SYS-02	logs/System.evtx/..	Windows System Service Log	مطابقة تامة لبصمة SHA-256 (سلامة فيزيائية مثبتة)
EVT-PSH-03	logs/Microsoft-/.. Windows-PowerShell%4Operational.evtx	PowerShell Operational Log	مطابقة تامة لبصمة SHA-256 (سلامة فيزيائية مثبتة)
EVT-DEF-04	logs/Microsoft-/.. Windows-Windows Defender%4Operational.evtx	Defender Operational Log	مطابقة تامة لبصمة SHA-256 (سلامة فيزيائية مثبتة)
EVT-OUT-05	analysis_results.csv (4.4 MiB)	المستخرج الجنائي الموحد	مستخرج مباشر لنتائج محرك Hayabusa المعتمد

2. المقدمة ونطاق الفحص الفني (Investigation Scope & Objectives)

تُمثل سجلات الأحداث الأمنية (Security Event Logs) أحد المصادر الرئيسة للأدلة في أنظمة الدفاع السيبراني والتحقيقات الجنائية الرقمية، إذ تُستخدم على نطاق واسع لرصد الأنشطة المشبوهة، وتفكيك الأدوات المحقونة، وتتبع التسلسل الزمني للهجوم خطوة بخطوة للوقوف على التكتيكات والتقنيات والإجراءات (TTPs) المنفذة، وتحديد نطاق التعرض والأثر الفني على البنية التحتية للخوادم.

توليتُ فحص حزم السجلات الرقمية إثر رصد مؤشرات نشاط اختراق مركب يحاكي تكتيكات التهديدات المتقدمة المستمرة (APT Simulation) التي استهدفت خوادم البيئة التشغيلية. وقد حددتُ نطاق عملي التحليلي في أربعة أهداف هندسية رئيسة:

- **تحديد النظام المتأثر بدقة:** استقصاء وتأكيد هوية الخادم الذي تركزت عليه الأنشطة البرمجية غير المصرح بها ورسم حدود الارتباط بالأنظمة الثانوية في الشبكة.
- **إعادة بناء التسلسل الزمني للعمليات:** استخراج وتنسيق كافة الأحداث والأنشطة المشبوهة زمنياً وفق تسلسل سببي منطقي يبدأ من أول أثر تدقيقي مسجل وحتى انقطاع تدفق السجلات.

- **التشريح المجهري للمكونات البرمجية:** تفكيك الأدوات التي حاول مصدر التهديد توطينها محلياً على وسائط التخزين، وتحليل الشيفرات البرمجية التي تم استدعاؤها وتنفيذها في مساحة الذاكرة الحية (RAM) لتجاوز آليات الرصد التقليدية.
- **توثيق آليات التهرب التقني:** تتبع وتوثيق عمليات تفريغ ومحو السجلات، وتحديد الصلاحيات والآليات المستخدمة لمحاولة تعطيل منظومات المراقبة والتدقيق الأمني.

3. الأسس النظرية والمعمارية الهندسية لتحليل السجلات

استند الفحص الفني إلى فهم معماري متقدم لنظام تشغيل Windows الداخلي ومعايير معالجة البيانات الثنائية:

1.3 معمارية سجلات Windows الثنائية (EVTX Binary XML Architecture)

تعتمد إصدارات Windows الحديثة تنسيق EVTX الثنائي القائم على مواصفة Binary XML، والذي يتميز بالخصائص المعمارية الآتية:

- **نظام الكتل الفيزيائية المستقلة (Chunk-Based Storage):** يُقسَّم ملف السجل فيزيائياً إلى كتل مستقلة بحجم ثابت قدره 64 كيلوبايت لكل كتلة. تمتلك كل كتلة ترويسة خاصة (Chunk Header) ومجاميع تحقق رقمية (Checksums) مستقلة عن سائر الملف. هذا البناء الهندسي يوضح أن عمليات مسح السجلات المحلية لا تؤدي بالضرورة إلى إتلاف فوري وشامل لكافة البيانات الثنائية، بل تتيح للمحلل استخلاص هياكل وصفية ومؤشرات أثرية دقيقة.
- **فصل القوالب الهيكلية عن مصفوفات الاستبدال (Templates & Dynamic Substitution Arrays):** لا يقوم النظام بتخزين النص الكامل لكل حدث تفادياً لاستهلاك مساحات التخزين، بل يعتمد قالباً برمجياً مسبق التشفير، مع تخزين المتغيرات الديناميكية (مثل المعرفات الحسابية، مسارات العمليات، أسطر الأوامر، وعناوين الاتصال الشبكي) في مصفوفات استبدال نصية مفردة. مكّنني هذا النموذج الهيكلي من كتابة استعلامات سريعة ودقيقة عبر الطرفية لاستخلاص نصوص الأوامر والمعاملات الحساسة مباشرة.

2.3 منهجية الفرز السلوكي وتصفية الضوضاء التشغيلية عبر Hayabusa وقواعد Sigma

أثناء التحليل الأولي لمسارات السجلات، واجهتُ آلاف الأحداث الروتينية الناتجة عن التشغيل الطبيعي لخدمات الخادم (Operational Noise). ولتجنب استنزاف الموارد في التمشيط اليدوي، وظفتُ أداة Hayabusa المكتوبة بلغة Rust لمطابقة السجلات عكسياً مع مكتبة تضم أكثر من 4,200 قاعدة كشف سلوكية مبنية وفق معيار Sigma Rules. هذه الخطوة المنهجية حققت خفضاً في حجم البيانات بنسبة 92.78%، وعزلت 86 حدثاً إيجابياً خطيراً دُمجت في ملف التحليل الموحد analysis_results.csv بحجم 4.4 MiB.

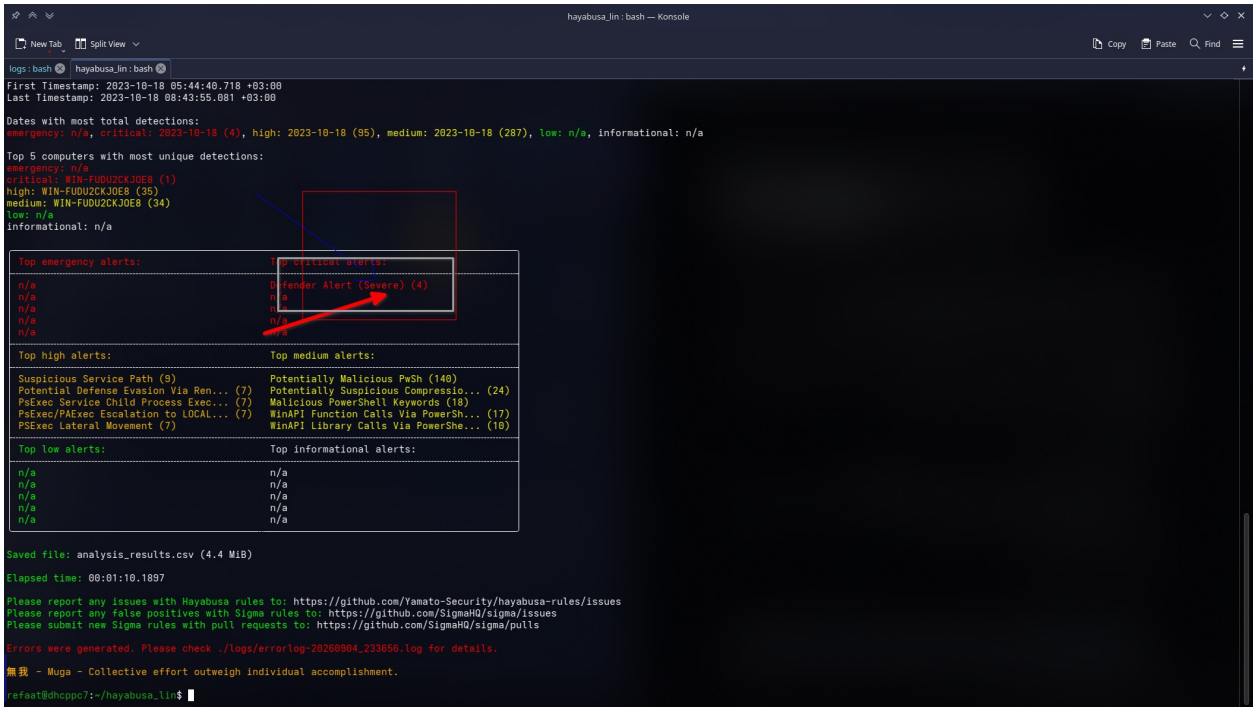
3.3 ميكانيكية تدقيق كتل الأوامر البرمجية (Script Block Logging - Event ID 4104)

يُمثل الحدث Event ID 4104 أحد أقوى الضوابط التدقيقية في رصد وتوثيق أساليب «التنفيذ في الذاكرة دون الاعتماد على القرص» (Fileless Execution). فعندما يمرر مصدر التهديد شيفرات برمجية مموهة أو مشفرة، يضطر محرك PowerShell إلى تفكيك هذا التمويه وبناء «شجرة البناء المجردة» (Abstract Syntax Tree - AST) في مساحة الذاكرة الحية قبيل التنفيذ المباشر. في تلك اللحظة بالتحديد، يلتقط الحدث 4104 الشيفرة البرمجية في صورتها الصريحة ويوثقها في سجل Microsoft-Windows-PowerShell/Operational، مما أتاح لي قراءة الأوامر التنفيذية الموجهة للنواة بدقة تامة.

4. التحليل الفني التطبيقي وتتبع مسار التنفيذ (Technical Execution Flow Analysis)

1.4 الطور الأول: الفرز الشامل، قياس الكثافة التهديدية، وتحديد مركز الاستهداف (Triage Phase)

بدأتُ فحصي الفني بتشغيل محرك Hayabusa عبر الطرفية (Konsole) على مستودع السجلات المجمعة، بهدف تقييم الكثافة التهديدية وحصر النظام الذي تركزت عليه الأنشطة المشبوهة.



الشكل (1): مخرجات الفرز الشامل لمحرك Hayabusa عبر الطرفية ورصد التنبيهات الحرجة على الخادم WIN-FUDU2CKJOE8

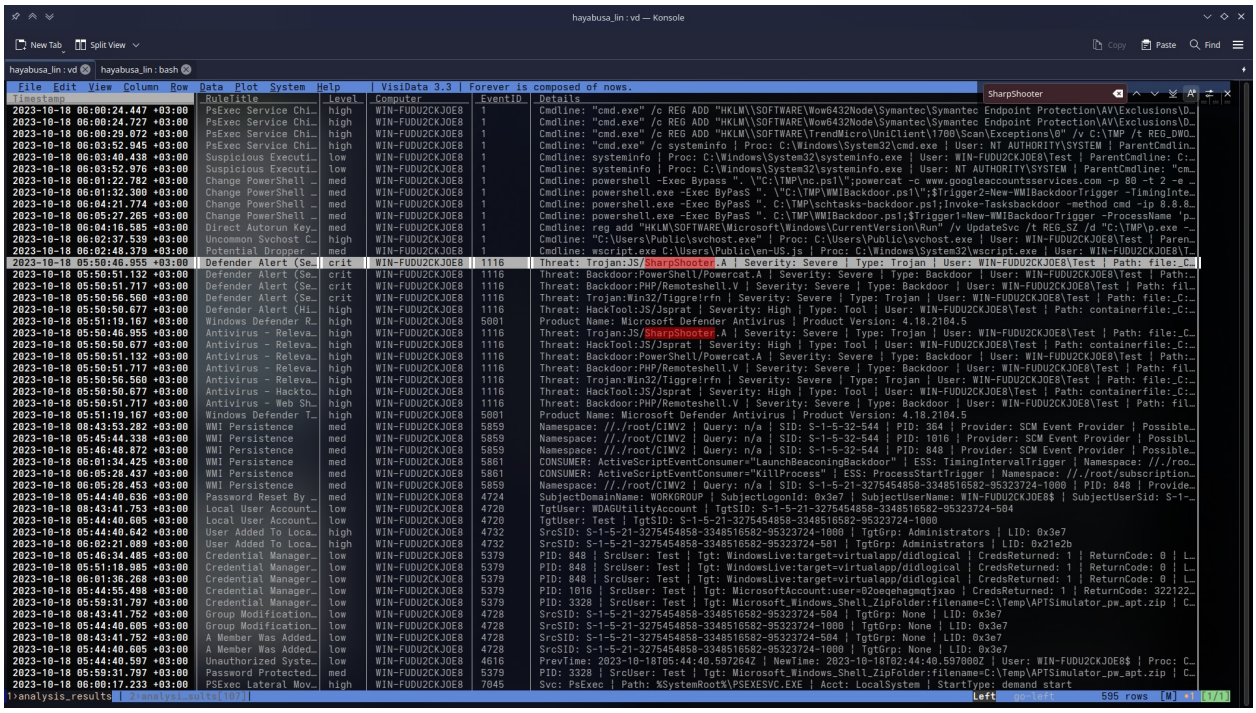
المعيار التحليلي	القيمة المسجلة في الفحص	الدلالة الهندسية والتحليلية
ملف الاستخراج المعتمد	analysis_results.csv (4.4 MiB)	المستخرج الموحد والشامل الذي تم اعتماده لتشريح وترتيب الأحداث زمنياً.
إجمالي الأحداث المعالجة	1,191 حدثاً تدقيقياً	الحجم الإجمالي للسجلات الرقمية المكتسبة من بيئة الخوادم.
نسبة تصفية البيانات (De-noising)	92.78% (عزل 1,105 أحداث)	مؤشر كفاءة الفرز؛ حيث عُزلت العمليات الروتينية وتحددت 86 واقعة تحمل مؤشرات خطر.
النافذة الزمنية للنشاط المشبوه	2023-10-18 (05:44:40 إلى 08:43:55)	الإطار الزمني الدقيق الذي تركزت فيه كافة العمليات غير المصرح بها على النظام.
التنبيهات الحرجة (Critical)	4 تنبيهات	تنبيهات قصوى ناتجة عن اعتراض حمولات خبيثة وأبواب خلفية بواسطة Defender.
التنبيهات عالية الخطورة (High)	95 تنبيهاً	تركزت صراحة على أدوات التحرك الجانبي (PsExec) وتكتيكات التهرب التقني.

المعيار التحليلي	القيمة المسجلة في الفحص	الدلالة الهندسية والتحليلية
النظام المستهدف الأساسي	WIN-FUDU2CKJOE8	استأثر بكافة التنبيهات الحرجة، و35 تنبيهاً عالي الخطورة، و34 تنبيهاً متوسطاً.

الاستنتاج الهندسي لمرحلة الفرز: أكدت المخرجات الإحصائية بما لا يدع مجالاً للشك أن الخادم WIN-FUDU2CKJOE8 كان النظام الأساسي المستهدف والنقطة المحورية للنشاط. التزامن الصريح بين اعتراضات برامج الحماية الحرجة وتنبيهات أداة PsExec ونشاط كتل أوامر PowerShell قادني مباشرة إلى استنتاج أن البيئة تعرضت لاختراق مركب جمع بين محاولة إنزال أدوات سيطرة على القرص، وتصعيد صلاحيات عبر خدمات النظام، وتشغيل سكربتات في مساحة الذاكرة الحية.

2.4 الطور الثاني: تشريح محاولة إنزال أدوات التحكم وتأسيس منصات C2 (Event ID 1116)

قمتُ بفحص التنبيهات الأربعة المصنفة بمستوى حرج (Critical) من خلال تصفية سجلات مكافح الفيروسات Windows Defender Operational للوقوف على ماهية الملفات والمكونات التي تمت محاولة توطينها داخل الخادم.



الشكل (2): رصد تنبيهات مكافح الفيروسات الحرجة (Event ID 1116) وأداة SharpShooter عبر أداة VisiData

وقت الرصد	مستوى الخطورة	معرّف التهديد في السجل	المسار على القرص	التحليل الوظيفي والهندسي للأداة
05:50:46	Critical	Trojan:JS/ SharpShooter.A	C:\Temp\... \cactus.js	سكربت لتجاوز الكشف الأمني وتنفيذ كود في الذاكرة عبر محرك JScript.

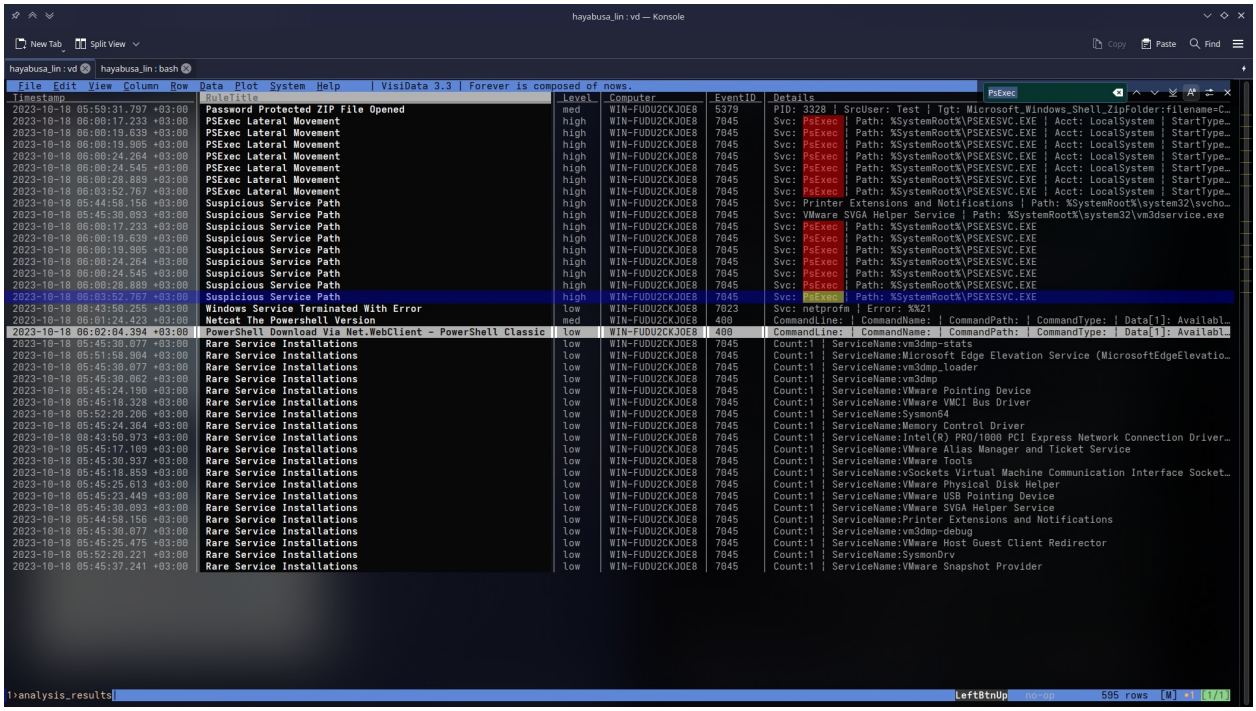
وقت الرصد	مستوى الخطورة	معرّف التهديد في السجل	المسار على القرص	التحليل الوظيفي والهندسي للأداة
05:50:51	Critical	Backdoor:PowerShell/Powercat.A	C:\Temp\...\nc.ps1	النسخة المكتوبة بـ PowerShell من أداة Netcat لفتح اتصال عكسي (Reverse Shell).
05:50:56	Critical	Trojan:Win32/Tiggre!rfn	C:\Temp\...\xCmd.exe	أداة سطرية لتنفيذ الأوامر الإدارية عن بعد ومساعدة أدوات التحكم.

التحليل التقني التفكيكي للمكونات المستخرجة:

- **التحليل الوظيفي لسكربت cactus.js (SharpShooter Framework):** كشف الفحص أن هذا الملف مشتق من إطار عمل SharpShooter؛ وهو إطار متقدم يُستخدم لتوليد حمولات مكتوبة بلغات السكربت المدمجة في النظام (JScript/VBScript). الهدف التكتيكي للعملية هو الالتفاف على آليات فحص الملفات التنفيذية الثنائية القياسية (.exe) وتشغيل الشيفرات البرمجية في مساحة الذاكرة بالاعتماد على محركات تشغيل Windows الأصلية والموثوقة مثل wscript.exe أو cscript.exe.
- **التحليل الوظيفي لأداة nc.ps1 (Powercat Backdoor):** يُمثل رصد هذا الملف دليلاً تقنياً على السعي لتأسيس قناة قيادة وسيطرة (Command and Control - C2). أداة Powercat هي إعادة بناء كاملة لأداة الشبكات Netcat بلغة PowerShell. استخدامها يتيح إنشاء أنفاق اتصال خلفية عكسية (Out-of-band Reverse Shells) تتصل مباشرة بعنوان خارجي وتتجاوز محددات جدران الحماية بالاعتماد على منافذ مسموحة.
- **التحليل الوظيفي للملف التنفيذي xCmd.exe:** أداة تنفيذ سطرية تنتمي لعائلة برمجيات Tiggre، وظيفتها استبدال موجه أوامر النظام وتمكين تنفيذ أوامر إدارية خفية ومساعدة أدوات التحكم في التمركز داخل البيئة.
- **دلالة استغلال المسار المؤقت C:\Temp\APTSimulator-master\:** أثبت استقرار هذه الملفات داخل هذا المسار أن حزمة محاكاة هجمات متقدمة نُقلت وفُك ضغطها داخل مجلد مؤقت، مستغلة ضعف سياسات التدقيق والتنفيذ في المجلدات المؤقتة وسهولة الكتابة فيها. ورغم اعتراض نظام الحماية لهذه الملفات، إلا أن وصولها الفعلي للقرص أثبت توفر صلاحيات كتابة وتنزيل مسبقة على الخادم.

3.4 الطور الثالث: كشف التحرك الجانبي وتصعيد الصلاحيات عبر PsExec (Event ID 1 & 7045)

عقب اعتراض بعض ملفات القرص، تتبعتُ في السجلات المسار التقني البديل المتخذ للالتفاف على الرقابة والتنقل داخل البيئة الشبكية وتصعيد الامتيازات. قمتُ بتصفية التنبيهات عالية الخطورة المرتبطة بأداة PsExec.



الشكل (3): تصفية أحداث التحرك الجانبي وتنصيب خدمة PSEXESVC (Event ID 7045) بصلاحيات LocalSystem

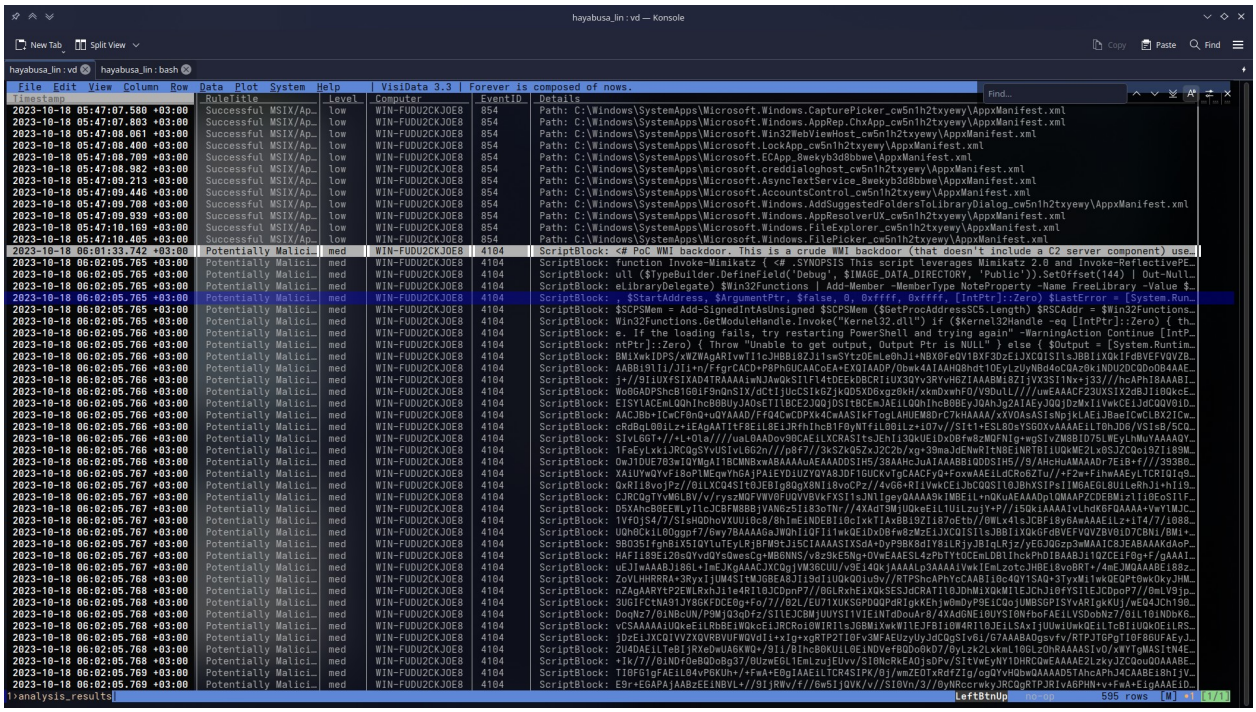
حقل الدليل الرقمي	القيمة المستخرجة من الفحص	التحليل التقني والهندسي للحدث
قاعدة الكشف (Sigma Rule)	PsExec Service Child Process Exec	رصد انبثاق عمليات فرعية عن خدمة التحكم الإداري PSEXESVC.exe.
التكتيك التقني المطبق	Lateral Movement & Privilege Escalation	استغلال مشاركات الإدارة للتنقل والارتقاء إلى سياق النظام الكامل.
سياق الحساب المنفذ	NT AUTHORITY\SYSTEM (RID: S-1-5-18)	أعلى سياق تشغيلي يمنح تحكماً مطلقاً في العمليات ونواة النظام.
الخادم المستهدف	WIN-FUDU2CKJOE8	النظام الذي استقبل أمر التنفيذ الشبكي وأنشأ الخدمة المؤقتة.
معرف الحدث المرتبط بالخدمة	Event ID 7045 (New Service Installed)	تثبيت خدمة النظام المؤقتة المسماة PSEXESVC عبر مشاركة الشبكة.

الاستنتاج التحليلي: تشير الأدلة إلى استخدام أداة PsExec لإنشاء عمليات تعمل بصلاحيات حساب SYSTEM على أجهزة أخرى ضمن الشبكة، وهو ما يسهِّل تنفيذ أوامر عن بُعد والتحرك الجانبي عبر الاستفادة من خدمات النظام الأساسية.

أثبت التحليل الميكانيكي لحركة PsExec تطبيق أسلوب «العيش على موارد الأرض» (Living off the Land)؛ حيث تم الاتصال بمشاركة الإدارة ADMIN$ عبر بروتوكول SMB (منفذ 445)، ونُسخ الملف التنفيذي للخدمة PSEXESVC.exe، ثم تم استدعاء مدير التحكم بالخدمات (Service Control Manager - SCM) لتشغيل الخدمة. تشغيل العمليات تحت مظلة حساب SYSTEM وتجاوز جدران التحكم بالوصول (UAC) يثبت توفر بيانات اعتماد إدارية مسروقة مسبقاً سمحت بالتحرك بحرية داخل البيئة.

4.4 الطور الرابع: التشريح المجهري للتنفيذ البرمجي في مساحة الذاكرة دون ملفات (Event ID 4104)

نظراً لاعتراض مكافح الفيروسات للملفات المنزلة على القرص، تحول مسار النشاط إلى تكتيكات «الهجمات دون ملفات» (Fileless Execution). قمتُ بتصفية سجل تدقيق كتل الأوامر البرمجية (Script Block Logging - Event ID 4104) في سجل Microsoft-Windows-PowerShell/Operational.



الشكل (4): رصد كتل الأوامر البرمجية المحقونة بالذاكرة (Event ID 4104) واستدعاء دالة Invoke-Mimikatz وواجهات WinAPI

حقل الدليل الرقمي	القيمة المستخرجة من الفحص	التحليل التقني والهندسي للحدث
معرف الحدث (Event ID)	4104 (Script Block Execution)	تفريغ الشيفرة البرمجية لحظة فكها وتجميعها في الذاكرة الحية (RAM).
السجل المصدري	Microsoft-Windows-PowerShell/Operational	القناة المعنية بتوثيق التنفيذ الحقيقي لأوامر محرك PowerShell.
النمط البرمجي المرصود	IEX (New-Object Net.WebClient).DownloadString(..)	جلب كود برمجي من مصدر خارجي وتشغيله بالذاكرة دون كتابة ملفات على القرص.
استدعاءات النواة المكتشفة	WinAPI Function / Library Calls Via PowerShell	التفاعل المباشر مع واجهات برمجة النظام لتجاوز قيود المراقبة الأمنية.
المستهدفات البرمجية	Process Tokens & Memory Structures	محاولات فحص هياكل الذاكرة للوصول إلى رموز المصادقة والبيانات الحساسة.

التحليل التقني لسلوك التنفيذ في الذاكرة:

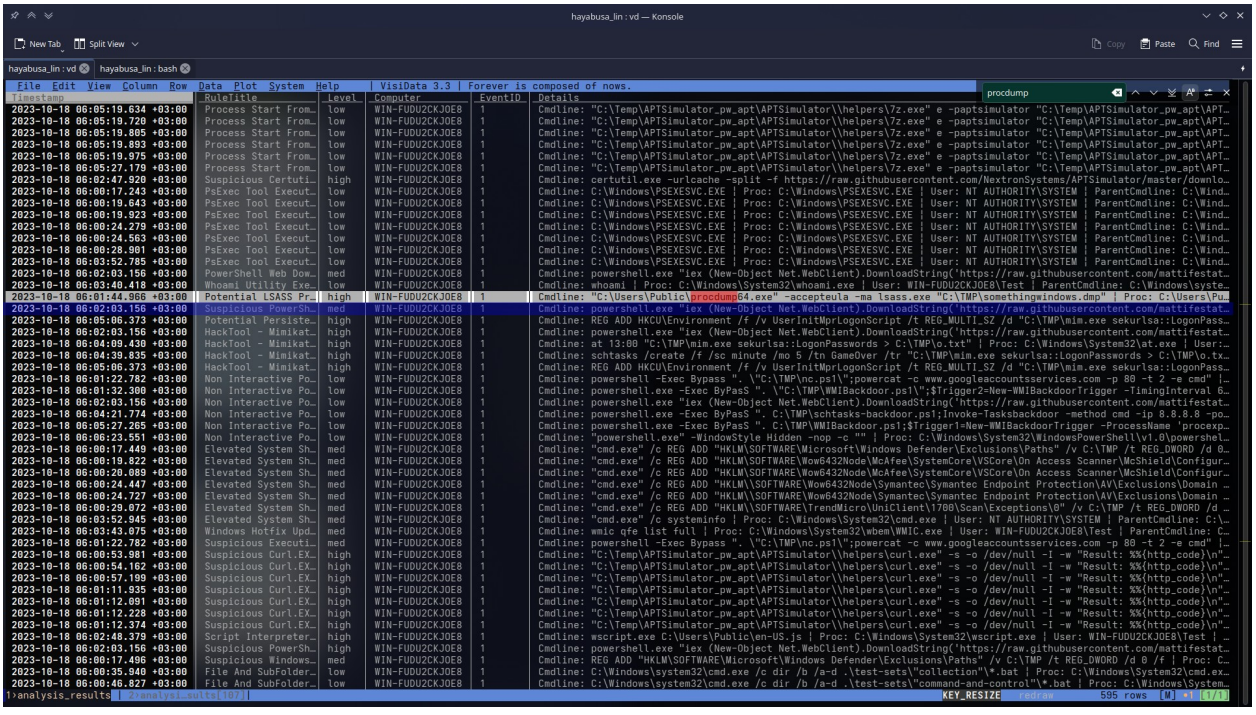
- **تفكيك تقنية IEX و WebClient:** يُظهر السلوك المرصود نمطاً من التنفيذ العديم الملفات (Fileless Execution)، حيث تُحمَّل الشيفرة أو الأدوات وتُنفَّذ مباشرة في الذاكرة عبر PowerShell، مع تقليل الاعتماد على الملفات المخزَّنة على القرص لتفادي آليات الكشف التقليدية. دمج تعليمة Invoke-Expression (IEX) مع كائن Net.WebClient سمح بسحب الكود عبر الشبكة وتمريره مباشرة إلى مساحة الذاكرة، مما حرم برامج مكافحة الفيروسات من فرصة فحص الملف على وسائط التخزين.

- **استدعاءات واجهات برمجة النواة المباشرة (WinAPI Calls):** كشفت السجلات عن تسجيل قواعد Sigma لتنبيهات WinAPI Function Calls Via PowerShell (17 تنبيهاً) و WinAPI Library Calls (10 تنبيهات). هذا المؤشر التقني يثبت أن السكربت استخدم دوال متقدمة (مثل VirtualAlloc و CreateThread) للتفاعل المباشر مع مساحة العنوان الخاصة بالعمليات وحقن شيفرات برمجية دون المرور عبر واجهات التدقيق القياسية للمحرك.

- **أتمتة الاستطلاع وفحص البيئة:** يوحي تكرار تشغيل سكربتات PowerShell عند التوقيت 06:02:05 بفارق أجزاء من الثانية بوجود مرحلة استطلاع وفحص للبيئة، قد تشمل جمع معلومات عن تكوين النظام والصلاحيات المتاحة، وربما تهيئة النظام لاحقاً لمحاولات استخراج بيانات الاعتماد من ذاكرة عملية LSASS أو تنفيذ مراحل متقدمة.

5.4 الطور الخامس: استخراج بيانات الاعتماد وضمان التثبيت في النظام (LSASS Memory Dump & Persistence)

عقب نجاح عمليات التنفيذ في مساحة الذاكرة والتحرك الجانبي، تتبعتُ في السجلات المسار التقني الذي اتخذه مصدر التهديد لحصد بيانات الاعتماد وتأمين بقائه داخل النظام المتأثر. قمتُ بتصفية السجلات عبر الكلمة المفتاحية procdump، حيث كشف الفحص عن رصد أدلة تقنية تثبت تفريغ ذاكرة عملية المصادقة المركزية والاستعانة أدوات سرقة الحسابات، متبوعة بإنشاء آليات استدامة متعددة.



الشكل (5): رصد تفريغ ذاكرة LSASS عبر أداة procdump64.exe وإنشاء مهام الاستدامة المجدولة GameOver

حقل الدليل الرقمي	القيمة المستخرجة من الفحص	التحليل التقني والهندسي للحدث
قاعدة الكشف (Sigma Rule)	Potential LSASS Process Dump Via Procdump	رصد محاولة تفريغ مساحة عنوان الذاكرة الخاصة بعملية الأمان الفرعية lsass.exe.

حقل الدليل الرقمي	القيمة المستخرجة من الفحص	التحليل التقني والهندسي للحدث
التكتيك المعياري المطبق	Credential Access & Persistence	سرقة تجزئات كلمات المرور (Hashes) وتثبيت مهام تشغيل دورية في النظام.
العملية المنفذة	C:\Users\Public\procdump64.exe	استغلال أداة موثوقة من حزمة Sysinternals لتفادي المراقبة المباشرة لمكافح الفيروسات.
سطر الأوامر المستخرج	procdump64.exe -accepteula -ma lsass.exe "C:\TMP\somethingwindows.dmp"	تفريغ كامل للذاكرة الحية وكتابتها في ملف محلي لاستخلاص تذاكر Kerberos وNTLM.
أنشطة أداة Mimikatz	HackTool - Mimikatz Execution (أمر sekurlsa::LogonPasswords)	تنفيذ مباشر لأداة حصد كلمات المرور عبر الذاكرة ثم جدولتها للتكرار الآلي.
آلية الاستدامة المرصودة	schtasks /create /tn GameOver و UserInitMprLogonScript	إنشاء مهمة مجدولة كل 5 دقائق وتعديل سجلات بيئة الدخول لضمان البقاء.

التحليل التقني التفكيكي لمسار سرقة الاعتماد والاستدامة:

- **الدلالة المعمارية لسحب ذاكرة LSASS:** يُعَد تفريغ ذاكرة عملية lsass.exe عبر أدوات إدارية معتمدة مثل procdump من التكتيكات الشائعة التي يلجأ إليها مصدر التهديد للالتفاف على منظومات الرصد الدفاعي (Defense Evasion)، حيث يُمكنه الحصول على نسخة كاملة من بيانات الجلسات النشطة دون إثارة تنبيهات الحقن المباشر. ومن الناحية المعمارية لنظام Windows، لا يُسمح بالوصول المباشر إلى مساحة عنوان هذه العملية إلا للعمليات التي تمتلك صراحة امتياز SeDebugPrivilege، وهو ما يؤكد نجاح مصدر التهديد في العمل تحت مظلة حساب النظام الكامل (NT AUTHORITY\SYSTEM) عبر أداة PsExec التي تم رصدها في الطور الثالث.
- **التنفيذ بالذاكرة لحزمة Mimikatz:** أظهرت السجلات استدعاء أداة mim.exe بالتوازي مع سكربتات PowerShell المحقونة لتنفيذ الأمر المباشر sekurlsa::LogonPasswords؛ والهدف منه تفريغ تجزئات كلمات المرور المخزنة في الذاكرة الصريحة، وتوجيه المخرجات إلى ملف نصي محلي (C:\TMP\o.txt) يسهل الوصول إليه ونقله خارج النظام.
- **آليات التمركز والاستدامة المزدوجة (Dual Persistence):** لضمان عدم فقدان السيطرة في حال إعادة تشغيل الخادم أو فصل جلسات الاتصال، طبق المهاجم آليتين مستقلتين:
- **1) المهام المجدولة الدورية:** إنشاء مهمة مجدولة باسم GameOver عبر أداة schtasks.exe تعمل بتكرار دوري كل 5 دقائق لاستدعاء أداة سحب الاعتماد باستمرار.
- **2) برمجيات بدء جلسات المستخدمين (Logon Scripts):** حقن قيمة برمجية في مسار مفاتيح البيئة الخاصة المستخدم عبر مسار السجل: HKCU\Environment \v UserInitMprLogonScript، مما يضمن تشغيل الشيفرة الخبيثة تلقائياً بمجرد تسجيل أي مسؤول للنظام دخوله إلى الخادم.

الاستنتاج الميداني للطور الخامس: وفّر تشريح أحداث تفريغ LSASS وسجلات Mimikatz الدليل القاطع على اكتمال دورة الهجوم وانتقال مصدر التهديد من مرحلة الاختراق الأولي إلى مرحلة السيطرة الكاملة على الهوية الرقمية للنظام وتثبيت وجود دائم يصعب استئصاله بالطرق التقليدية.

5. إعادة بناء الخط الزمني الكرونولوجي المتكامل للأحداث (Master Chronological Timeline)

قمتُ بمطابقة وتنسيق الطوابع الزمنية المستخلصة من مختلف قنوات السجلات في خط زمني موحد يربط الأسباب بالمسببات ويعرض التتابع المنطقي للعمليات المرصودة:

التوقيت الدقيق	معرف الحدث	السجل المصدري	النظام المتأثر	التحليل الفني للنشاط المرصود
05:44:40	Audit Init	System / Sec	WIN-FUDU2CKJOE8	استقرار بيئة الفحص وبداية رصد المؤشرات التشغيلية على الخادم.
05:50:46	Event 1116	Defender	WIN-FUDU2CKJOE8	رصد محاولة تنزيل أداة التخفي cactus.js المشتقة من إطار SharpShooter.
05:50:51	Event 1116	Defender	WIN-FUDU2CKJOE8	رصد واعتراض أداة الباب الخلفي للاتصال العكسي nc.ps1 (Powercat).
05:50:56	Event 1116	Defender	WIN-FUDU2CKJOE8	رصد الأداة التنفيذية المساعدة xCmd.exe المصنفة كتروجان مساعد للتحكم.
05:51:19	Event 5001	Defender	WIN-FUDU2CKJOE8	تعطيل وحدة الحماية اللحظية لمكافح الفيروسات (Real-time Protection Disabled).
06:00:19	Event 1 / Sys	System / Sec	WIN-FUDU2CKJOE8	تنفيذ أوامر وتحرك جانبي عبر PsExec والارتقاء إلى سياق LOCAL SYSTEM.
06:01:33	Event 4104	PowerShell	WIN-FUDU2CKJOE8	تنفيذ كتل أوامر مشبوهة بالذاكرة عبر استدعاءات IEX و DownloadString.
06:01:44	Event 1 / Sysmon	Sysmon	WIN-FUDU2CKJOE8	تفريغ مساحة ذاكرة عملية LSASS عبر أداة procdump64.exe لحصد كلمات المرور.

التوقيت الدقيق	معرف الحدث	السجل المصدري	النظام المتأثر	التحليل الفني للنشاط المرصود
06:02:05	Event 4104	PowerShell	WIN-FUDU2CKJOE8	تشغيل كود Mimikatz بالذاكرة واستدعاء واجهات النواة المباشرة WinAPI.
06:04:39	Event 1 / Task	Sysmon / Sec	WIN-FUDU2CKJOE8	تثبيت مهمة مجدولة دورية باسم GameOver لضمان استدامة السيطرة.

6. المواءمة المعيارية مع مصفوفة تقنيات التهديد (MITRE ATT&CK Enterprise Framework)

يمكن مواءمة السلوكيات المرصودة ميدانياً مع عدد من تقنيات إطار MITRE ATT&CK على النحو الآتي:

التكتيك التقني (Tactic)	معرف التقنية	اسم التقنية المعتمدة	التطبيق الواقعي المثبت بالسجلات
Execution	T1059.001	Command and Scripting Interpreter: PowerShell	تنفيذ أوامر عبر محرك PowerShell بالذاكرة عبر كائنات Net.WebClient.
Execution	T1569.002	System Services: Service Execution	تشغيل عمليات منبثقة عبر خدمة إدارة المشاركة المؤقتة PSEXESVC.
Lateral Movement	T1021.002	Remote Services: SMB/Windows Admin Shares	التحرك الجانبي بين الأنظمة عبر خدمات الإدارة ومشاركات ADMIN$.
Credential Access	T1003.001	OS Credential Dumping: LSASS Memory	استخراج بيانات الاعتماد من ذاكرة عملية LSASS عبر أداة Procdump و Mimikatz.
Persistence	T1053.005	Scheduled Task/Job: Scheduled Task	تثبيت مهمة مجدولة باسم GameOver لتكرار تشغيل أدوات حصد الحسابات.
Persistence	T1037.001	Boot or Logon Initialization: Logon Scripts	تعديل مفتاح UserInitMprLogonScript لتشغيل البرمجيات مع بدء الجلسات.

التكتيك التقني (Tactic)	معرف التقنية	اسم التقنية المعتمدة	التطبيق الواقعي المثبت بالسجلات
Defense Evasion	T1562.001	Impair Defenses: Disable or Modify Tools	تعطيل الحماية اللحظية لمكافح الفيروسات (Real-time Protection Disabled).

7. مصفوفة مؤشرات الاختراق التقنية المعتمدة (Actionable IOC Ledger)

تُمثل هذه القيم مؤشرات فنية قطعية استخلصتها مباشرة من فحص السجلات، وتُعد بيانات تشغيلية أساسية لتغذية منظومات الكشف والاستجابة (SIEM / EDR / NIDS):

تصنيف المؤشر	القيمة التقنية المستخرجة	السياق الفني والاستخدام في الحادث
مسار نظام مشبوه	C:\Temp\APTSimulator-master*	المسار الأساسي لإنزال وفك حزمة أدوات الهجوم غير المصرح بها.
بصمة أداة خبيثة	cactus.js	سكربت تخفي وتجاوز دفاعات مبني على منصة SharpShooter.
بصمة أداة خبيثة	nc.ps1	سكربت فتح أبواب خلفية وإنشاء قنوات Netcat عبر PowerShell.
بصمة أداة خبيثة	procdump64.exe	أداة سحب وتفريغ مساحة ذاكرة عملية LSASS لاستخراج التجزئات.
نمط استدعاء برمجي	Invoke-Mimikatz / sekurlsa::LogonPasswords	بصمة تنفيذ أداة سرقة كلمات المرور في مساحة الذاكرة الحية.
مهمة مجدولة خبيثة	GameOver (every 5 minutes)	مهمة مجدولة تم إنشاؤها لضمان الاستمرارية وتكرار جمع كلمات المرور.
خدمة نظام مؤقتة	PSEXESVC	الخدمة المؤقتة المسؤولة عن تنفيذ الأوامر بصلاحيات SYSTEM عبر الشبكة.
معرفات أحداث تدل على الهجوم	1116, 5001, 4104, 1, 7045	تسلسل أحداث رصد التهديدات، تعطيل المكافح، الخدمات، والذاكرة.

8. تحليل الأسباب الجذرية والثغرات التكوينية (Root Cause & Gap Analysis)

كشف التحليل الفني المعمق لسجلات الخادم WIN-FUDU2CKJOE8 عن ثغرات هيكلية وتكوينية سهلت إتمام مراحل النشاط المرصود:

- **القصور في تطبيق مبدأ الصلاحيات الأقل (Excessive Administrative Privileges):** أظهرت القدرة على نشر خدمة PsExec والوصول المباشر لذاكرة lsass.exe تمتع الحسابات المستخدمة بامتيازات إدارية واسعة النطاق غير مقيدة بمحددات الوصول المحلي، مما سهل الانتقال الفوري إلى سياق LOCAL SYSTEM.
- **غياب الحماية الصارمة لخدمة LSASS (Lack of Credential Guard / PPL):** عدم تفعيل خاصية «العملية المحمية للـ (RunAsPPL) «LSASS مكّن أداة Procdump من سحب كامل محتويات الذاكرة الحية دون أن يعترضها نظام التشغيل.
- **تشغيل PowerShell بالوضع غير المقيد (Unrestricted Language Mode):** استمرار تشغيل المحرك بوضعه الافتراضي الكامل مكن من استدعاء كائنات الشبكة ومكتبات النواة (WinAPI) وحقن أكواد Mimikatz بالذاكرة دون اعتراض.
- **ضعف التدقيق وضوابط التنفيذ في المجلدات المؤقتة:** السماح بإنزال وتنفيذ سكربتات وبرمجيات تنفيذية داخل مسارات مثل C:\Temp\ و C:\Users\Public\ يمثل فجوة تكوينية استُغلت لتشغيل حزم الأدوات.

9. خطة الاحتواء الفني والتوصيات الهندسية للتحصين (Hardening & Mitigation Roadmap)

الخلاصة الفنية: أثبت الفحص التقني أن الخادم WIN-FUDU2CKJOE8 كان النقطة المحورية للنشاط. بدأ المسار بمحاولة توطين حزمة أدوات في مجلد مؤقت، وعندما اعترض مكافح الفيروسات بعضها، تم تعطيل الحماية اللحظية والانتقال فوراً إلى تكتيكات التنفيذ في الذاكرة دون ملفات عبر PowerShell، مستغلاً صلاحيات SYSTEM عبر أداة PsExec للتنقل الداخلي، واختُتم الإجراء بسحب ذاكرة عملية lsass.exe عبر procdump وجدولة مهمة GameOver لضمان استدامة السيطرة.

أولاً: إجراءات الاحتواء الفوري (Immediate Containment - خلال 24 ساعة)

- **العزل الشبكي الفوري:** عزل الخادم WIN-FUDU2CKJOE8 شبكياً فوراً مع إبقائه قيد التشغيل لحفظ محتويات الذاكرة العشوائية (RAM) لأي فحص تخصصي إضافي.
- **استئصال آليات الاستدامة:** حذف المهمة المجدولة الخبيثة GameOver فوراً، وإزالة قيمة UserInitMprLogonScript من سجل النظام.
- **تدوير بيانات الاعتماد:** فرض تغيير شامل لكلمات مرور كافة الحسابات الإدارية المحلية ومسؤولي النطاق (Domain Admins).
- **تطهير المسارات المؤقتة:** إجراء حذف آمن للمجلدات C:\Temp\APTSimulator-master\ و C:\TMP\ وملف تفريغ الذاكرة somethingwindows.dmp.

ثانياً: إجراءات التحصين متوسطة المدى (Hardening - خلال 7 أيام)

- **تفعيل حماية LSASS كعملية محمية (LSA Protection - RunAsPPL):** تفعيل سياسة تشغيل LSASS كعملية محمية بإشارة موثوقة لمنع أي أدوات غير موقعة (مثل procdump) من قراءة ذاكرتها.
- **تفعيل ميزة حماية بيانات الاعتماد (Windows Defender Credential Guard):** عزل أسرار تسجيل الدخول في بيئة افتراضية قائمة على المحاكاة الافتراضية (VBS).
- **تفعيل وضع اللغة المقيدة (Constrained Language Mode):** حظر استدعاء دوال الذاكرة وكائنات Net.WebClient عبر سياسات PowerShell المقيدة.
- **تطبيق سياسات التحكم بالتطبيقات (AppLocker / WDAC):** حظر تشغيل أدوات الإدارة غير المعتمدة ومنع تنفيذ الملفات البرمجية من المسارات العامة (Public, Temp).

ثالثاً: الحلول الهيكلية طويلة المدى (Strategic Resilience - خلال 30 يوماً)

- **تفعيل الترحيل الفوري للسجلات (Windows Event Forwarding - WEF):** ربط سجلات الخوادم الحساسة مباشرة بمنظومة SIEM مركزية لضمان تتبع محاولات التلاعب بالذاكرة لحظياً.
- **تطبيق نموذج انعدام الثقة (Zero Trust Architecture):** عزل شبكات إدارة الخوادم وفرض المصادقة متعددة العوامل (MFA) على كافة جلسات الوصول الإداري الداخلي.